

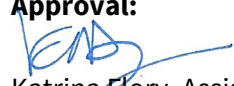


DAS Policy

Audit and Accountability

No:
2100-12

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to define **Audit** and **Accountability** requirements of **Information Systems** that will assist in assessing the adequacy of system controls, ensuring compliance with established policies and operational procedures, and uniquely tracing the actions of system **Users**.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology Special Publication 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations," family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable.

II. Scope

The scope of this policy includes Information Systems that are developed or acquired by the Ohio Department of Administrative Services (DAS). This policy also applies to DAS data, **Service Owners**, and **System Owners**.

III. Policy

Information Systems shall be configured to produce, store, and retain **Audit Records** for specific system, application, network, and User activity. Procedures shall be developed to guide the implementation and management of Audit controls. The procedures shall be consistent with applicable laws, Executive Orders, directives, policies, regulations, standards, and guidance. In addition, Audit procedures shall be reviewed annually and updated as necessary.

- A. **Auditable Events (AU-2):** Information Systems shall be configured to generate an Audit Record for a pre-defined set of events that are adequate to support after-the-fact security

Incident investigations. The selection of **Auditable Events** shall be based upon the results of a data classification assessment that is conducted in accordance with Ohio Administrative Policy IT-13, "Data Classification," a risk assessment conducted in accordance with DAS Policy 2100-08, "Risk Assessment," and a Privacy Impact Assessment conducted in accordance with Ohio Revised Code (ORC) 1347.15. These assessments shall identify which events require continuous Auditing, and which events require Auditing in response to specific situations in accordance with DAS IT Standard DAS-ITS-2100-12, "Auditable Events."

1. Auditable events and review frequencies shall be documented. The documentation shall be evaluated on an annual basis and updated as necessary.
 2. At a minimum, event Audit requirements shall include recording the date, timestamp, logon/logoff and failed access attempts for operating systems, databases and applications.
 3. **Privileged Functions**, including changes in the status of Auditable events, shall generate Audit Records and shall be Audited.
 4. Only authorized personnel shall be allowed to make changes to the Audit system. Changes to the Audit system may include adjustments to capture more or less information to comply with investigation requirements, as well as modifications that would facilitate **Audit Reduction**, analysis and reporting.
 5. Systems shall have the capability to meet any legal requirements for logging and other accounting of User activities. Systems maintaining **Confidential Personal Information (CPI)** within the scope of ORC 1347.15 shall have a mechanism for recording specific access by agency employees to CPI. For example, the recording mechanism may include application logging access or passing the employee's identifier to the database using a monitoring tool.
- B. **Content of Audit Records (AU-3):** Information Systems shall have the capability to include specific information in Audit Records. Audit Records shall contain sufficient information to establish what events occurred, when the events occurred, the source of the events, the identity of any User associated with the event and the event outcome. **Audit Logs** shall be forwarded to a centralized Audit management system.
- C. **Audit Storage Capacity (AU-4):** A sufficient amount of Information System storage capacity shall be allocated for Audit Records. Information Systems shall be configured to reduce the likelihood of Audit Records exceeding such storage capacity.
- D. **Response to Audit Processing Failures (AU-5):** Information Systems shall provide the capability to generate Information System alerts and send them to the appropriate personnel in the event of an Audit failure or Audit storage capacity being reached. In the event of an Audit

processing failure, the system shall shut down or provide limited functionality, based on the outcome of the risk assessment conducted in accordance with DAS Policy 2100-08, "Risk Assessment."

- E. **Audit Review, Analysis and Reporting (AU-6)**: Information System Audit Records shall be regularly reviewed and analyzed to identify unauthorized, inappropriate, unusual, or suspicious activity. Such activity shall be investigated and reported to the appropriate officials, in accordance with DAS Policy 2100-07, "Incident Response," and agency Incident response procedures.
1. As a minimum, Audit Records shall be reviewed and analyzed at least weekly by the System Owner, and reporting shall be directed to the appropriate contacts. If there is an increased risk to operating systems, databases or applications, review and analysis shall be performed more frequently.
 2. Audit review, analysis and reporting processes shall be integrated to support investigations and subsequent responses to suspicious activities.
 3. Audit Records shall be analyzed and correlated across different repositories to gain organizational situational awareness.
- F. **Audit Reduction and Report Generation (AU-7)**: The centralized Audit management system shall automatically process Audit Records for events of interest based upon selectable event criteria. The system shall also summarize the Auditable events.
- G. **Timestamps (AU-8)**: Audit Records shall employ timestamps for use in Audit record generation. Timestamps of Audit Records shall be generated using internal system clocks that are synchronized to a recognized network time protocol source.
- H. **Audit Information Protection (AU-9)**: Audit information and Audit tools shall be protected from unauthorized access, modification, and deletion.
1. Audit Logs shall be protected from unauthorized modification, access, or deletion while online and during offline storage:
 - a) Only authorized system administrators, and the designated security personnel for the system, are permitted access to Audit Logs and Audit tools.
 - b) Audit Logs containing sensitive information, such as CPI or ***Personally Identifiable Information*** (PII), shall be encrypted.
 2. A monthly review of Audit Logs and access shall be executed to detect any instances of unauthorized access, modification, or deletion.
- I. **Nonrepudiation (AU-10)**: Information Systems shall protect against an individual falsely denying having performed a particular action.

- J. **Audit Record Retention (AU-11)**: Audit Records shall be retained to provide support for after-the-fact investigations of security incidents and to meet regulatory and record retention requirements. Electronic record management requirements are outlined in Ohio Administrative Policy IT-07, "Electronic Records."
- K. **Audit Generation (AU-12)**: The Information System provides Audit record generation capability for the Auditable events defined in Section A. Audit Records shall be generated for the events defined in Section A. with the content defined in Section B. System Owners shall select which events are to be Audited by specific components of the Information System.

IV. Definitions

- A. **Accountability**. The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity.¹
- B. **Audit**. A review and examination of Information System records and activities to assess the adequacy of system controls, to ensure compliance with established policies and operational procedures, and to recommend necessary changes in controls, policies, or procedures.²
- C. **Audit Logs**. A record showing who has accessed a computer system and what operations have been performed during a given time period. Audit Logs are useful both for maintaining information technology security and recovering lost transactions.
- D. **Audit Records**. A compilation of details of an action performed by a system User or process that is captured by an Information System in an effort to create an Audit trail of system activity. This activity can include system changes, as well as capturing details associated with viewing records contained in a system. Audit records often include, but are not limited to, information such as date/time stamps, User identification, action attempted, success and/or failure of action.
- E. **Audit Reduction**. Concept designed to reduce the volume of Audit records to facilitate manual review. This principle is often used to remove Audit records generated by a specified class of events known to have little security significance. For example, records generated by nightly backups may be determined to provide little or no security significance; and therefore, would not be considered when assessing security events.

¹ Nieves, Michael, Kelley Dempsey, Victoria Yan Pillitteri, "NIST Special Publication 800-12 Revision 1, An Introduction to Information Security," U.S. Department of Commerce National Institute of Standards and Technology, June, 2017 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>>.

² "NIST Special Publication 800-32, Introduction to Public Key Technology and the Federal PKI Infrastructure," U.S. Department of Commerce National Institute of Standards and Technology, February, 2001 <<https://csrc.nist.gov/publications/nistpubs/800-32/sp800-32.pdf>>.

- F. Auditable Events. Actions performed by a system User or process which results in an Audit record being written to an Audit Log.
- G. Confidential Personal Information (CPI). Personal information that falls within the scope of section 1347.15 of the Ohio Revised Code and that an agency is prohibited from releasing under Ohio's public records law.
- H. Incident. A security Incident threatens the confidentiality, integrity or availability of state information resources.
- I. Information System. A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.³
- J. Nonrepudiation. Protection against an individual falsely denying having performed a particular action. Provides the capability to determine whether a given individual took a particular action such as creating information, sending a message, approving information, and receiving a message.⁴
- K. Personally Identifiable Information. "Personally Identifiable Information" is information that can be used directly or in combination with other information to identify a particular individual. It includes:
 - 1. a name, identifying number, symbol, or other identifier assigned to a person,
 - 2. any information that describes anything about a person,
 - 3. any information that indicates actions done by or to a person,
 - 4. any information that indicates that a person possesses certain personal characteristics.⁵
- L. Privileged Functions. Security-relevant functions that ordinary Users are not typically authorized to perform. Privileged Functions are often associated with network and/or system administrators and accounts with root-level authority.
- M. Service Owner. A service owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.
- N. System Owner. Person responsible for the development, procurement, integration, modification, operation and maintenance, and/or final disposition of an information system.
- O. User. An individual or (system) process authorized to access an Information System.⁶

V. Authority

ORC 125.18

³ NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁴ *Ibid.*

⁵ Based on Ohio Revised Code Section 1347.01 (E).

⁶ "FIPS 200, Minimum Security Requirements for Federal Information and Information Systems." U.S. Department of Commerce National Institute of Standards and Technology, March 2006
<<https://csrc.nist.gov/publications/fips/fips200/FIPS-200-final-march.pdf>>.

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio Revised Code 1347.15, Access rules for Confidential Personal Information	https://codes.ohio.gov/ohio-revised-code
Ohio Administrative Policy IT-07 Electronic Records	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
Ohio IT Standard ITS-SEC-01 Data Encryption and Cryptography	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-07 Incident Response	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-08 Risk Assessment	https://das.ohio.gov/technology-and-strategy/policies
DAS Standard DAS-ITS-2100-12-A Auditable Events	https://das.ohio.gov/technology-and-strategy/policies
DAS Standard DAS-ITS-2100-12-B Application Security Log Output Standard	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/22/2017	Original Policy
12/04/2018	Conducted scheduled maintenance review, no changes were made to the policy as a result.
02/26/2020	Updated the policy template to align with the current format.
06/22/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.